

TP02_B3_S3_BEAUVALLET : Test d'intrusion1

Table des matières

1) Problématique.....	1
2) Exercice 1 : Terminologie	1
2) Exercice 2 : Test de connexion des deux VMs	2
3) Exercices de la phase de reconnaissance.....	2
4) Conclusion.....	5

1) Problématique

On souhaite définir une méthodologie de test d'intrusion afin d'identifier les vulnérabilités d'un système informatique et de pouvoir le sécuriser.

Pour cela, nous allons étudier les principales méthodologies, définir les différentes étapes d'un pentest, puis mettre en place une machine attaquante Kali Linux et une machine victime Windows 7.

2) Exercice 1 : Terminologie

Voici un tableau regroupant les définitions de ces différents termes : OWASP, PTES, OSSTMM, NIST.

Sigle	Signification	Description
OWASP	Open Worldwide Application Security Project	Organisation à but non lucratif spécialisée dans la sécurité des applications, notamment les applications web.
PTES	Penetration Testing Execution Standard	Standard qui définit une méthodologie et les différentes étapes à suivre pour réaliser un test d'intrusion de manière structurée.
OSSTMM	Open Source Security Testing Methodology Manual	Manuel proposant une méthodologie pour réaliser des tests de sécurité de manière organisée et reproductible sur différents systèmes.
NIST	National Institute of Standards and Technology	Organisme américain qui publie des normes, recommandations et guides dans différents

		domaines, notamment la cybersécurité et les tests de sécurité.
--	--	--

2) Exercice 2 : Test de connexion des deux VMs

Nous allons maintenant vérifier si les deux machines sont bien connectées entre elles. Pour cela on vérifie d'abord les IPs des deux machines avec **ipconfig** pour Windows et **ip** pour Kali :

```
C:\Users\uboxuser>ipconfig

Configuration IP de Windows

Carte Ethernet Connexion au réseau local :
    Suffixe DNS propre à la connexion. . . . : 
    Adresse IPv6 de liaison locale. . . . . : fe80::c09f:7bdc:2c74:ff59%11
    Adresse IPv4. . . . . : 192.168.56.102
    Masque de sous-réseau. . . . . : 255.255.255.0

2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixro
```

Ensuite on utilise la commande **ping ipdelamachineàcontacter** (soit 192.168.56.101 pour Kali soit .102 pour Windows) :

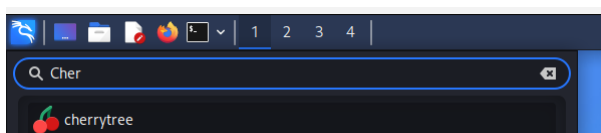
```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixro
ute eth0
    valid_lft 521sec preferred_lft 521sec
    inet6 fe80::aa32:50c5:1d5b:6b24/64 scope link noprefixroute
    valid_lft forever preferred_lft forever

(kali㉿kali)-[~]
└─$ ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.061 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.045 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.029 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.026 ms
64 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=0.028 ms
64 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=0.036 ms
64 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=0.036 ms
64 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=0.040 ms
```

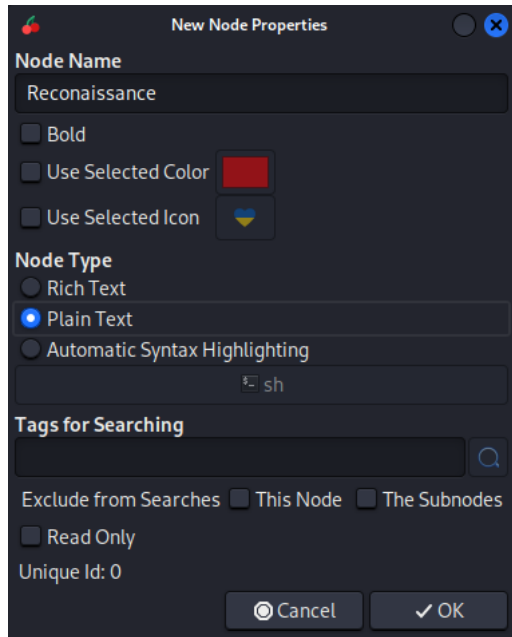
3) Exercices de la phase de reconnaissance

Ex 1 : Créer une section reconnaissance dans CherryTree

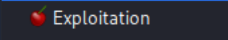
Nous allons utiliser la machine Kali Linux, on clique donc sur le petit logo de dragon en haut à gauche puis on cherche « CherryTree » :

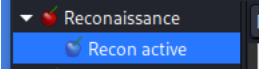


Lorsqu'on est sur l'interface de cherrytree, on clique sur le bouton  puis on nomme notre nœud « Reconnaissance » et on clique sur « OK » :

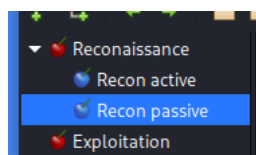


Exercice 2 à 4 (similaire au 1 donc que je fusionne) : Création arborescence

On crée une section Exploitation  puis on sélectionne notre nœud Reconnaissance et on clique sur le bouton ajouter un enfant . On nomme cet enfant

« Recon active » : 

Et on crée encore un nœud qui s'appellera cette fois-ci « Recon passive », et on montre que l'on sait transformer un nœud en nœud enfant simplement en glissant déposant le nouveau nœud dans le nœud Reconnaissance :



Exercice 5 : Spiderfoot

a) Dans kali on clique sur le dragon puis on cherche « spiderfoot » et on ouvre le programme avec ce nom.

b) Dans la ligne de commande on élève notre position avec **sudo su** :

```

-T, --types          List available event types.
-o {tab, csv, json}  Output format. Tab is default.
-H                  Don't print field headers, just data.
-n                  Strip newlines from data.
-r                  Include the source data field in tab/csv output.
-S LENGTH            Maximum data length to display. By default, all
                    data is shown.
-D DELIMITER         Delimiter to use for CSV output. Default is ,.
-f                  Filter out other event types that weren't requested
                    with -t.
-F type1,type2, ... Show only a set of event types, comma-separated.
-x                  STRICT MODE. Will only enable modules that can
                    directly consume your target, and if -t was
                    specified only those events will be consumed by
                    modules. This overrides -t and -m options.
-q                  Disable logging. This will also hide errors!
-V, --version        Display the version of SpiderFoot and exit.
-max-threads MAX_THREADS
                    Max number of modules to run concurrently.
sh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$
$ sudo su
sudo] password for kali:
(root@kali)~/home/kali$
#

```

c) -l signifie listen et elle permet de définir sur quelle adresse IP et quel port le serveur web doit démarrer.

d) On démarre le serveur web spiderfoot avec la commande **spiderfoot -l ipkali:80**

```

(root@kali)~/home/kali$
# spiderfoot -l 192.168.56.101:80

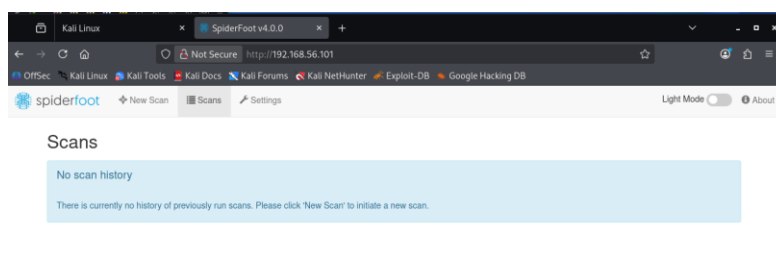
usr/lib/python3/dist-packages/adblockparser/parser.py:247: SyntaxWarning: "\
" is an invalid escape sequence. Such sequences will not work in the future.
Did you mean "\\w"? A raw string is also an option.
rule = rule.replace("^", "(?:[^\w\d_\.%]|$)")
usr/lib/python3/dist-packages/adblockparser/parser.py:272: SyntaxWarning: "\
" is an invalid escape sequence. Such sequences will not work in the future.
Did you mean "\\|"? A raw string is also an option.
rule = re.sub("(\\|)[^$]", r"\\|", rule)
026-09-22 03:10:38,921 [INFO] sf : Starting web server at 192.168.56.101:80
..

026-09-22 03:10:38,935 [WARNING] sf :
*****
Warning: passwd file contains no passwords. Authentication disabled.
Please consider adding authentication to protect this instance!
Refer to https://www.spiderfoot.net/documentation/#security.
*****

*****
Use SpiderFoot by starting your web browser of choice and
browse to http://192.168.56.101:80/
*****

```

Puis on ouvre le navigateur et on se dirige sur le lien que l'on voit sur la ligne de commande :

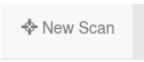


Exercice 6 : HackerOne et scan de test

HackerOne est une plateforme de cybersécurité de premier plan qui met en relation les entreprises et une communauté internationale de hackers éthiques

(IMPORTANT : je me suis aperçu que je n'avais pas internet car j'utilisais un réseau privé pour faire marcher le ping entre les deux machines virtuelles. J'ai donc simplement mis le réseau priver en Adaptateur 2 pour la VM Kali et j'ai mis en Nat l'adaptateur 1)

Ex 7 : Scan

On clique sur  puis on donne un nom au scan et une cible :

Scan Name

HackerOne

Scan Target

hackerone.com

On laisse le Use Case sur l'option All puis on clique sur **Run Scan Now** :

Run Scan Now

(Ma VM crash lorsque je scan... donc je m'arrête là)

4) Conclusion

En conclusion, j'ai appris quels étaient les différents outils permettant d'effectuer une phase de reconnaissance lors d'un test d'intrusion tel que spiderfoot et cherrytree. J'ai appris à utiliser spiderfoot afin d'effectuer des analyses de domaines et d'IPs.